Lab 3b: Cybersecurity Risk Quantification

SecureBank Financial, SecureMobile Banking Platform

Name: Madubuonu Chisom Anthonia
Date: 30 October 2026

SecureBank's SecureMobile app has about 500,000 active customers and handles around 50,000 transactions a day. A security assessment found three vulnerabilities. In this report I work out how much each one could cost per year, compare three possible controls and recommend what the bank should do.

Data from the lab

Vulnerability	Exploit probability	Exposure	Loss basis
API Authentication Bypass	15%	Transaction processing system	Maximum single incident loss $5,000,000; detection takes 48 hours
Database Injection	25%	500,000 customer records	$250 per record (regulatory and notification costs)
Session Hijacking	40%	5,000 simultaneous sessions	$1,500 average loss per account

Control	Initial cost	Annual maintenance	Effectiveness
Advanced API Security Gateway	$350,000	$50,000	90% reduction in API vulnerabilities
Web Application Firewall (WAF)	$150,000	$25,000	75% reduction in web vulnerabilities
Multi-Factor Authentication Enhancement	$200,000	$30,000	95% reduction in account takeover

The lab does not say which control covers which vulnerability, so I made a choice. I matched the WAF to the database injection (it is a web vulnerability), MFA to session hijacking (account takeover) and the API gateway to the API bypass.

Phase 1: Risk exposure

Task 1: Annualized loss expectancy

SLE is the loss from one incident and ARO is how often it is expected to happen in a year. I used the exploit probability as the ARO. ALE = SLE × ARO.

Vulnerability	SLE	ARO	ALE
API Authentication Bypass	$5,000,000 (maximum single incident loss)	0.15	$5,000,000 × 0.15 = $750,000
Database Injection	500,000 × $250 = $125,000,000	0.25	$125,000,000 × 0.25 = $31,250,000
Session Hijacking	5,000 × $1,500 = $7,500,000	0.40	$7,500,000 × 0.40 = $3,000,000
Total			$35,000,000

Task 2: Risk prioritization matrix

Vulnerability	SLE	ARO	ALE	Share of total	Priority	Heat map rating
Database Injection	$125,000,000	0.25	$31,250,000	89.3%	1 (Critical)	High
Session Hijacking	$7,500,000	0.40	$3,000,000	8.6%	2 (High)	High
API Authentication Bypass	$5,000,000	0.15	$750,000	2.1%	3 (Medium)	Low

I ranked by ALE. An ALE of $10 million or more is critical, $1 million to $10 million is high, and anything lower is medium. For the heat map I called a probability of 35% or more high and under 20% low, and an impact of $10 million or more high and under $1 million low. These cut-offs are my own choice, because the lab does not give any.

Task 3: Visualizations

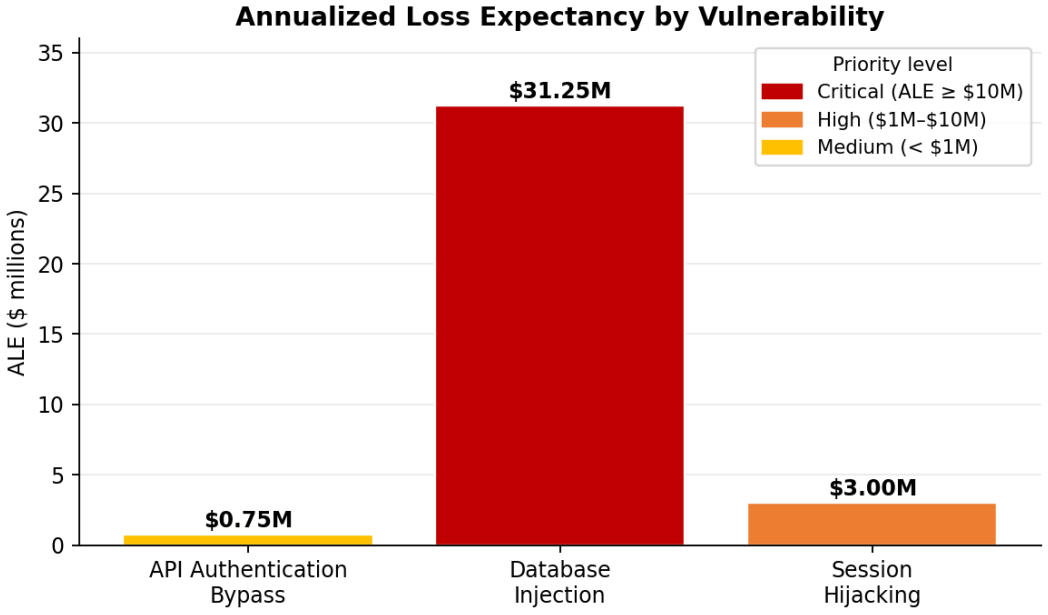


Figure 1: ALE by vulnerability

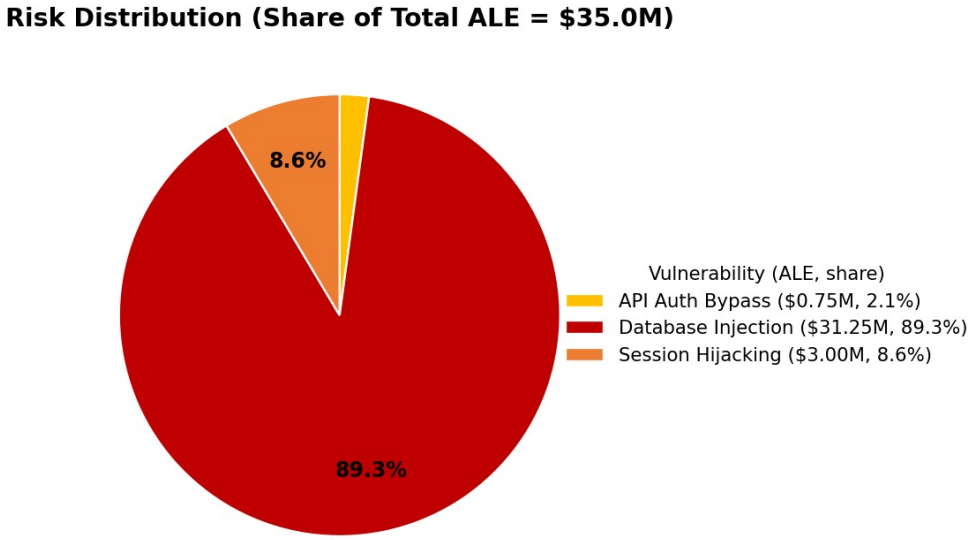


Figure 2: Share of total ALE

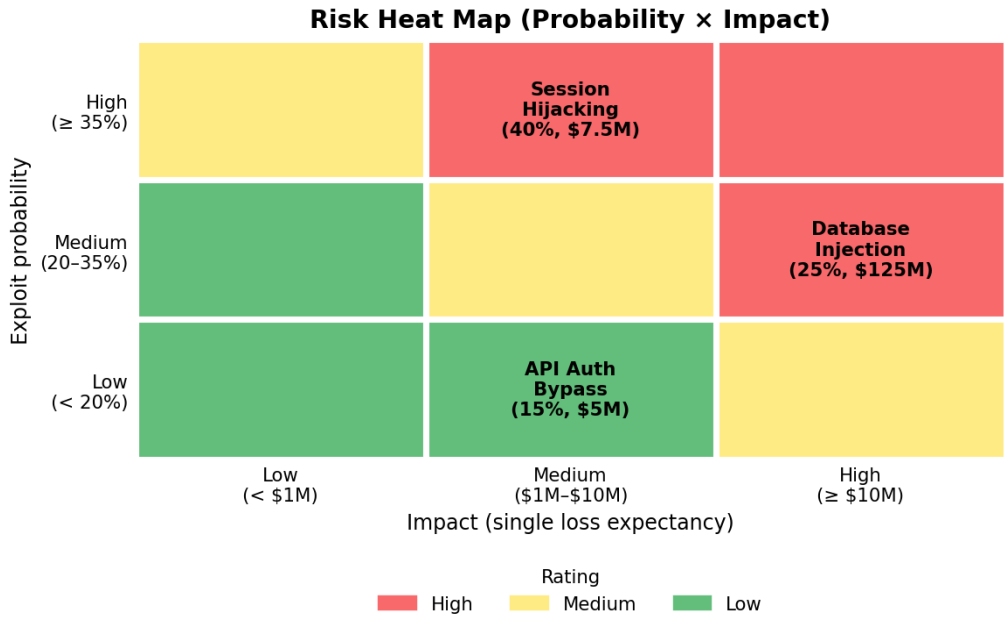


Figure 3: Risk heat map

Database injection makes up about 89% of the total modeled loss. Even at a 25% chance, losing 500,000 records at $250 each is a very large single loss. Session hijacking is the most likely event (40%), but it costs far less.

Phase 2: Control evaluation

Task 4: Cost-benefit analysis

Control	Initial cost	Annual maint.	Risk reduction per year	Year-1 net benefit	ROI (year 1)	Payback
API Security Gateway	$350,000	$50,000	$675,000	$275,000	68.75%	6.7 months (204 days)
WAF	$150,000	$25,000	$23,437,500	$23,262,500	13,293%	2.3 days
MFA Enhancement	$200,000	$30,000	$2,850,000	$2,620,000	1,139%	25.9 days

Risk reduction is the ALE of the vulnerability the control covers times its effectiveness. For the API gateway that is $750,000 × 0.90 = $675,000. For the WAF it is $31,250,000 × 0.75 = $23,437,500. For MFA it is $3,000,000 × 0.95 = $2,850,000.

Year-1 cost is the initial cost plus one year of maintenance: $400,000 for the gateway, $175,000 for the WAF and $230,000 for MFA. ROI = (risk reduction - year-1 cost) / year-1 cost. That gives $275,000 / $400,000 = 68.75% for the gateway, $23,262,500 / $175,000 = 132.93 (13,293%) for the WAF and $2,620,000 / $230,000 = 11.39 (1,139%) for MFA.

Payback = initial cost / (annual risk reduction - annual maintenance). For the gateway that is $350,000 / $625,000 = 0.56 years. For the WAF it is $150,000 / $23,412,500 = 0.0064 years, and for MFA $200,000 / $2,820,000 = 0.071 years.

All three controls together	Value	Working
Initial investment	$700,000	$350,000 + $150,000 + $200,000
Annual maintenance	$105,000	$50,000 + $25,000 + $30,000
Year-1 cost	$805,000	$700,000 + $105,000
Total risk reduction	$26,962,500	77.0% of $35,000,000
Residual ALE	$8,037,500	$35,000,000 - $26,962,500
Year-1 net benefit	$26,157,500	ROI of 3,249%

Task 5: Charts for choosing controls

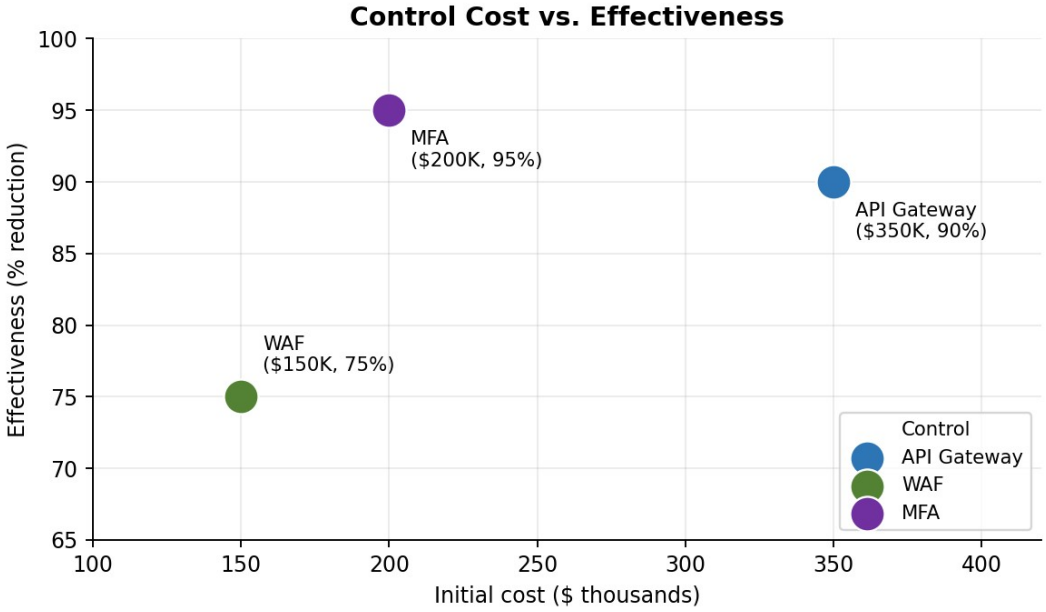


Figure 4: Cost against effectiveness

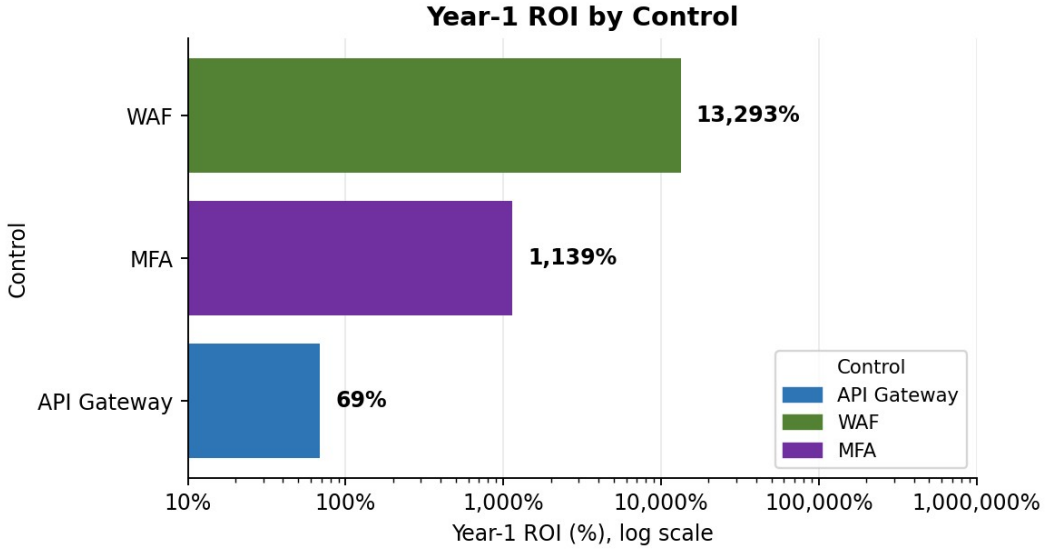


Figure 5: Year-1 ROI by control (log scale)

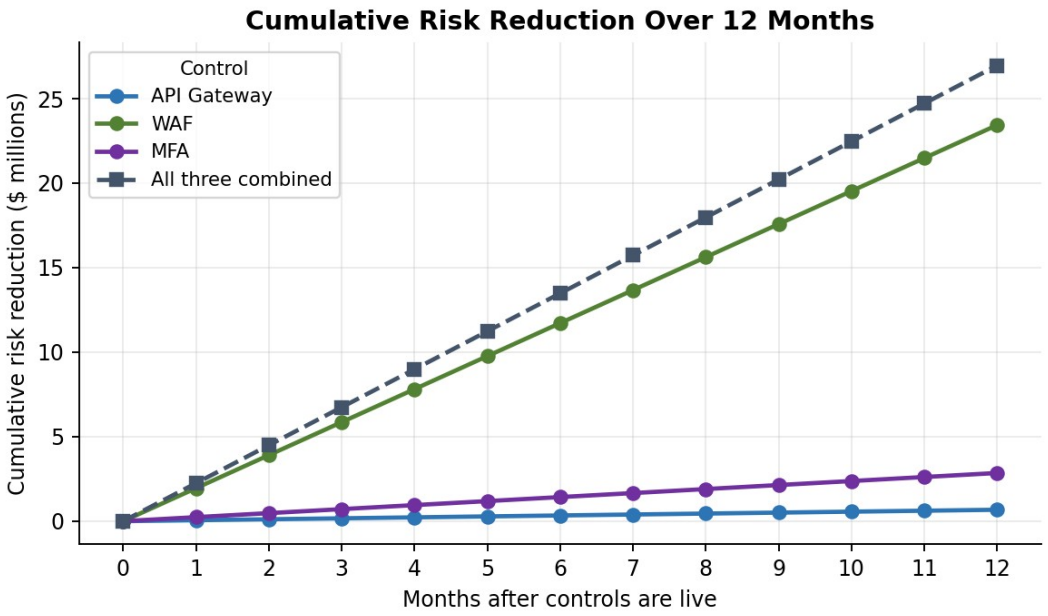


Figure 6: Cumulative risk reduction over 12 months

The WAF is the cheapest control and also removes the most risk, so it comes out best on every measure. MFA is the most effective at 95% and pays for itself in under a month. The API gateway is the weakest value because it protects against the smallest risk. I used a log scale on the ROI chart because the values run from 69% to 13,293%.

Phase 3: Executive reporting

Task 6: One-page dashboard

SecureBank SecureMobile: Risk Dashboard

$35.00M	$8.04M	77.0%	$26.16M
Total ALE (before)	Residual ALE (after)	Risk reduction	Year-1 net benefit

Top 3 risks (financial impact)

1. Database injection – ALE $31.25M (SLE $125M × 25%)
2. Session hijacking – ALE $3.00M (SLE $7.5M × 40%)
3. API authentication bypass – ALE $0.75M (SLE $5M × 15%)

Recommended controls (cost → ROI)

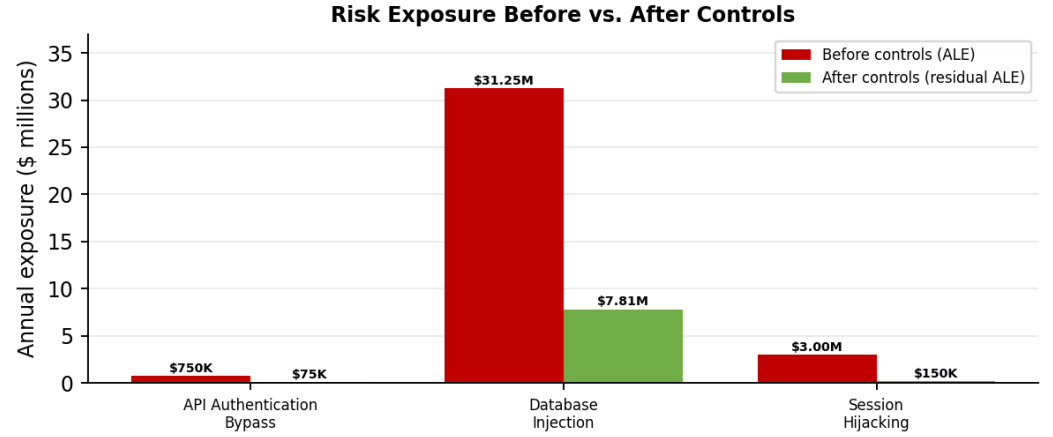
WAF: $175K yr-1 → ROI 13,293%, payback ~2 days

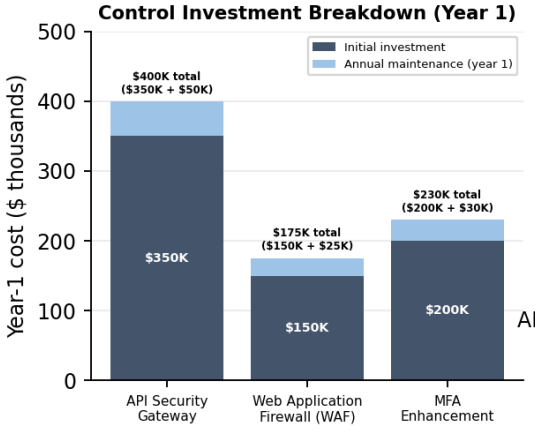
MFA: $230K yr-1 → ROI 1,139%, payback ~26 days

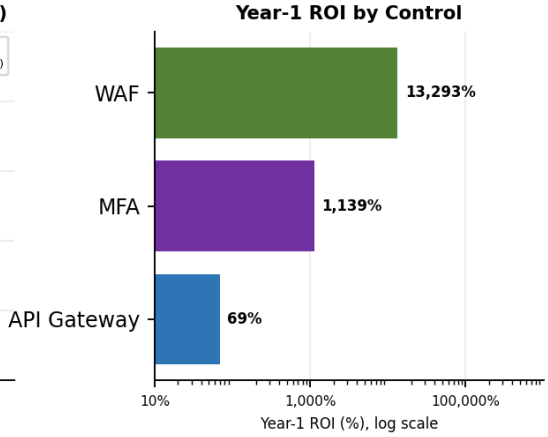
API Gateway: $400K yr-1 → ROI 69%, payback ~6.7 mo

Combined: $700K initial + $105K/yr maintenance = $805K year-1 cost.
ALE falls $35.00M → $8.04M; combined year-1 ROI 3,249%.

Largest remaining risk: database injection residual $7.81M – fix the code, not only the WAF.







Risk treatment plan

Task 7: Timeline

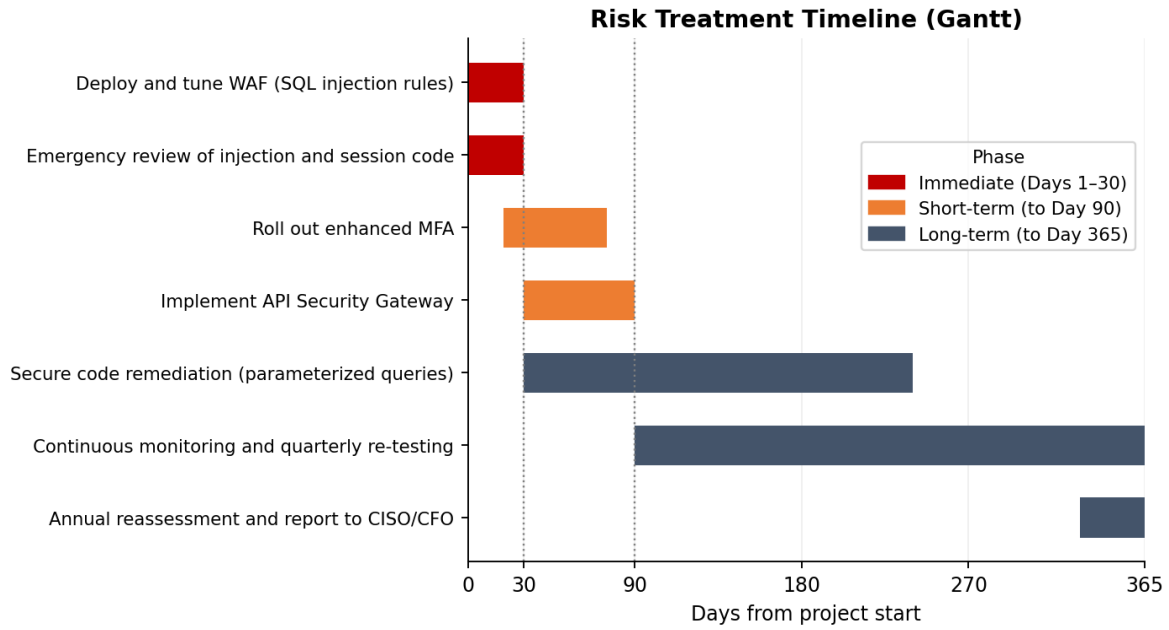


Figure 7: Risk treatment timeline

Phase	Actions	Reason
Immediate (first 30 days)	Deploy and tune the WAF. Review the injection and session handling code urgently.	This is the biggest risk (89% of ALE) and the WAF pays back in about 2 days.
Short term (90 days)	Roll out enhanced MFA. Implement the API Security Gateway.	MFA pays back in about 26 days. The gateway is the lowest priority.
Long term (1 year)	Fix the code (parameterized queries). Continuous monitoring and quarterly re-testing. Annual reassessment.	Removes the root cause. The WAF alone leaves $7.8M of database risk.

Financial justification

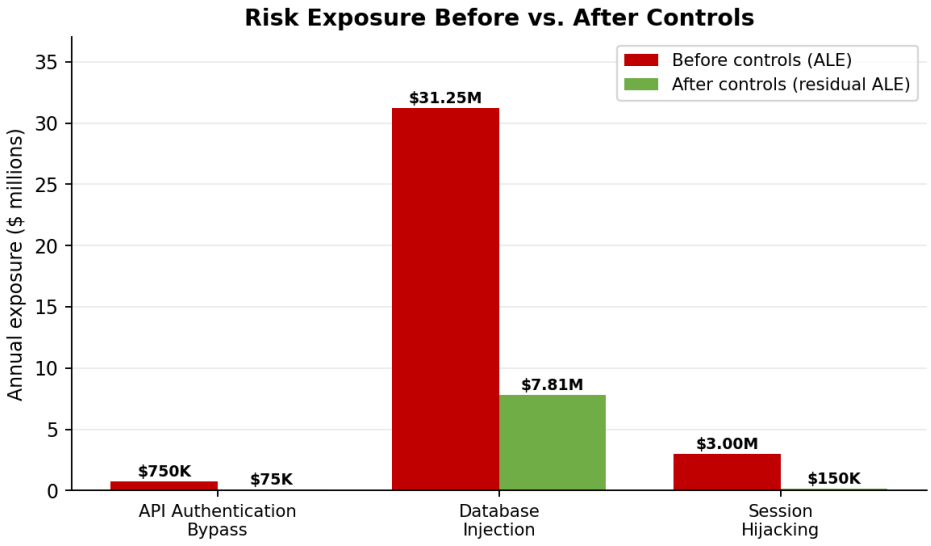


Figure 8: Exposure before and after controls

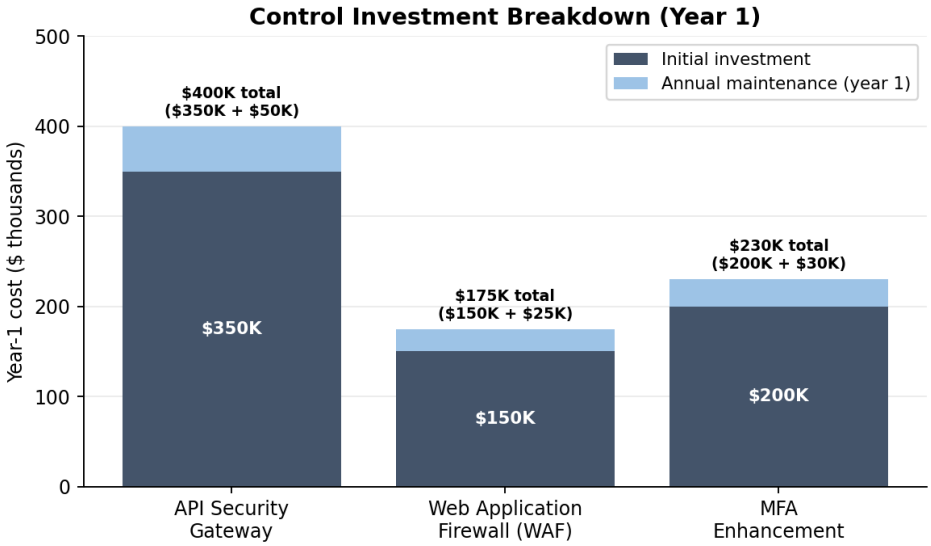


Figure 9: Year-1 cost of each control

Metric	Before	After	Change
Total ALE	$35,000,000	$8,037,500	-$26,962,500 (-77.0%)
Database injection ALE	$31,250,000	$7,812,500	-75%
Session hijacking ALE	$3,000,000	$150,000	-95%
API bypass ALE	$750,000	$75,000	-90%

Bonus: combined risk-control matrix

Vulnerability	Current ALE	Control	Residual ALE	Risk reduction	Year-1 control cost
API bypass	$750,000	API Gateway	$75,000	$675,000	$400,000
Database injection	$31,250,000	WAF	$7,812,500	$23,437,500	$175,000
Session hijacking	$3,000,000	MFA	$150,000	$2,850,000	$230,000
Total	$35,000,000		$8,037,500	$26,962,500	$805,000

If the budget is limited, I would rank the controls by risk reduction per dollar of year-1 cost: WAF 133.9, MFA 12.4 and API gateway 1.7. Then I would fund them in that order until the money runs out.

Year-1 budget	Controls funded	Risk reduction	Residual ALE	Reduction
$0	None	$0	$35,000,000	0%
$175,000	WAF	$23,437,500	$11,562,500	67.0%
$405,000	WAF + MFA	$26,287,500	$8,712,500	75.1%
$805,000	WAF + MFA + API Gateway	$26,962,500	$8,037,500	77.0%

The first $175,000 (the WAF) delivers about 87% of the total benefit. The API gateway adds only $675,000 of reduction for $400,000, which is the smallest return of the three.

Assumptions and limits

I treated the exploit probability as the chance of the event happening once a year, since the lab gives probabilities and not past frequencies. The SLE values assume the worst case: all 500,000 records exposed, all 5,000 sessions hijacked and the full $5,000,000 for the API. Real incidents could be smaller. I also applied each effectiveness percentage straight to the ALE, which is cleaner than real vendor results usually are.

The control matching described at the start is my own assumption. ROI uses year-1 cost only, so over several years it would improve, because only the maintenance repeats. As a quick check I halved all the probabilities. The ranking stayed the same (WAF 6,596% and MFA 520%), but the API gateway dropped to -15.6%, so it would not pay for itself in the first year.

The WAF is a stop-gap and not a fix, which is why $7.8 million of database risk is still left. The daily transaction figures were not needed for these calculations, and the API loss is capped at the lab's $5 million even though 48 hours of undetected fraud could in theory cost more. I also treated the three vulnerabilities as independent and left out reputational damage.